Rubric for Lab Work (5%)

LAB NO.:	**4:Threat Variance: Suricata XSS (CySOP**	**SEM/TRADE:**	4/DCBS1
GROUP MEMBERS:	1. ABDUL HARIZ BIN MOHD SARNUDIN	**TTO:**	**Mohamad Aiman Hanif**
		MARKS:	**/20**

		MARKS				
No.	**Criteria**	**NEEDS IMPROVEMENT [1]**	**APPROACHES EXPECTATIONS[2]**	**MEETS EXPECTATIONS [3]**	**EXCELLENT [4]**	
GROUP LABWORK						**Marks**
1.	**Understanding on Topology of the scenario**	Cannot develop understanding on the scenario topology	Able develop understanding on the scenario topology but still not accurate and detail	Clear, accurate understanding explanation of the scenario topology with diagrams and complete but with NO example	Clear, accurate understanding explanation of the topology with diagrams and complete example.	
2	**Knowledge on lab objectives and concepts**	Students failed to demonstrate clear understanding of the lab objectives and concepts.	Students demonstrates some knowledge of the lab objectives and concepts.	Student demonstrates sufficient level of the lab objectives and concepts.	Student demonstrates well verse of the lab objectives and concepts.	
3	**Lab completion**	Not able to achieve any of lab objectives and show any output.	Able to achieve some lab objectives and show some output.	Able to achieve most of lab objectives and	Able to completely achieve all lab objectives	

				show most of the output.	and show all of the output.	
4	**Interpreting Findings**	Students failed to interpret the findings and result.	Student able to interpret some of the findings and result, but in a somewhat unclear manner.	Students able to interpret most of the findings and result.	Student able to interpret all the findings and result clearly and comprehensively.	
5	**Level of Needed assistance**	Student was unable to complete task with assistance.	Student was unable to complete task without major assistance.	Student was able to complete the task with little assistance.	Student was able to complete the task without assistance.	
TOTAL MARKS:		**/20**				

ASSESSOR COMMENT:	

Answer all questions:

1. Explain the topology requirement of the lab. You may use diagram to support your explanation.

   The topology requirement for this lab involves an Ubuntu Linux analysis workstation that is accessed remotely through a Remote Desktop Connection at the IP address 100.100.50.89. This centralized node runs the core network security and host analysis tools which are Wireshark, Suricata and ClamAV. Within this environment, the internal target host being monitored is defined as $HOME_NET with the local IP address 192.168.136.25. The external network or malicious destination handler is defined as $EXTERNAL_NET at the IP address 177.128.2.2 which communicates over SMTP port 587. Suricata functions as a network intrusion detection system positioned logically to parse traffic moving between these internal and external points to log suspicious events

2. Explain your expectation from this lab. What is your achievement before and after lab completion.

   My expectation for this lab was to learn how to actively detect and analyze threat variances at both the network and host levels using Suricata and ClamAV. Before completing this lab, I had a general theoretical understanding of signature matching but lacked actual experience writing custom detection rules, interpreting raw protocol data flows or establishing localized hash databases. After completing the lab, I achieved the practical skill required to isolate threat indicators from a live Wireshark packet capture, write functional Suricata rules using flowbits to track sequential session changes and successfully implement a custom cryptographic signature database (.hdb) to recognize unofficial malware files inside ClamAV

3. Did you able to complete the lab successfully (YES/NO)? Explain why and how. Demonstrate and explain the output you achieve from this lab.

YES, I was able to complete the lab successfully. I achieved this by following the procedural phase boundaries which included inspecting the raw network traffic capture, drafting custom detection syntax in the Suricata configuration files and executing signature update directories within ClamAV to verify endpoint system status.

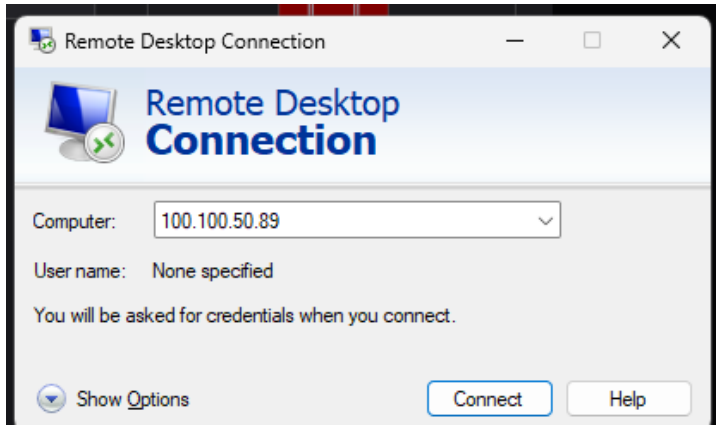
For the lab outputs, I opened the agent_tesla_dump.pcap file in Wireshark and found an SMTP stream showing an AUTH LOGIN PLAIN sequence along with stolen data like User Name and OSFullName. After adding these indicators into custom.rules, Suricata successfully generated matching alerts in fast.log for the connection between the IPs 192.168.136.25 and 177.128.2.2. For ClamAV, the first scan on the Downloads folder flagged 1 infected file out of 49. The next scan on the Linux-Malware-Samples folder found 475 infected files out of 502 and after moving the NewSignature.hdb file into the system folder, the files were correctly detected with the UNOFFICIAL FOUND tag

4. Interpret the result and your findings? Your explanation may include how Suricata can be used to mitigate XSS attacks.

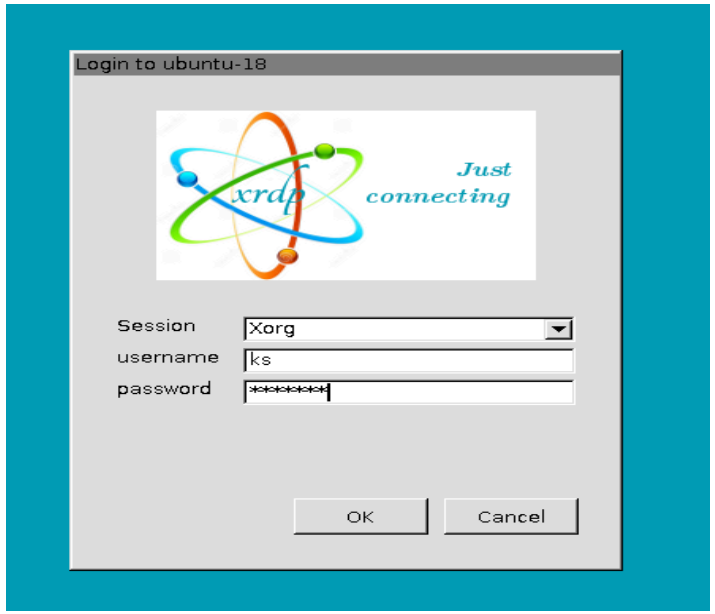
The results show an Agent Tesla spyware campaign where the malware collects system info from the victim and sends it to an external server over SMTP port 587. By using Suricata rules with flowbits, we can link different parts of the network session to get accurate alerts. Combining this with ClamAV helps catch variations of the malware files using custom hashes.

To stop Cross-Site Scripting (XSS) attacks, Suricata needs to run in inline IPS mode instead of passive detection. This lets us write rules to inspect HTTP traffic fields like http.uri or http.request_body. The rules scan for malicious indicators like script tags, javascript protocols and DOM events like onerror or onload. If a match is found, Suricata drops the packet so the attack never reaches the backend web server.

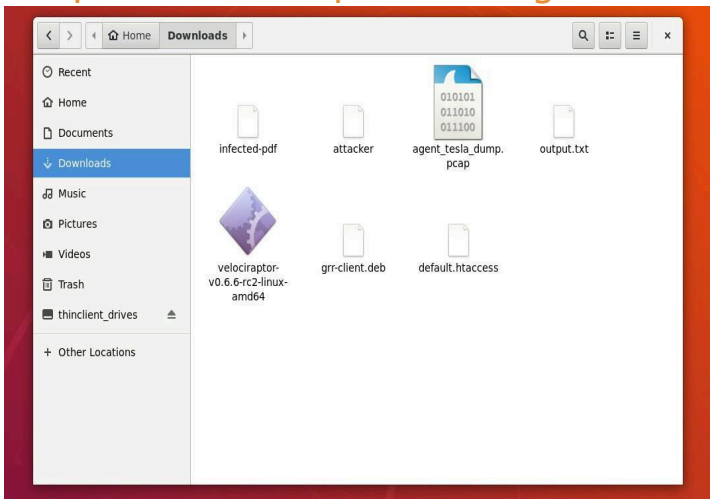
1. Access the Ubuntu Linux using telnet



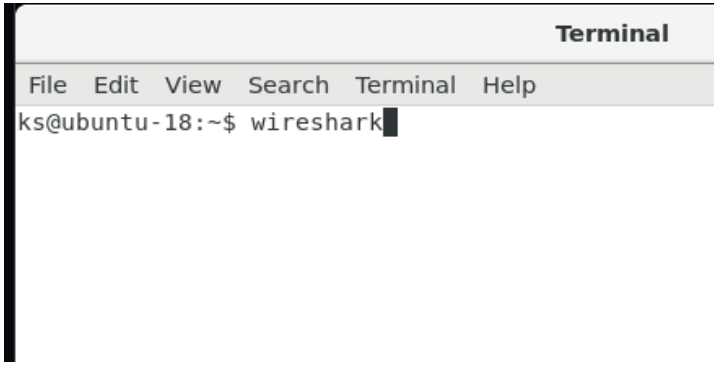
2. Input the login credentials



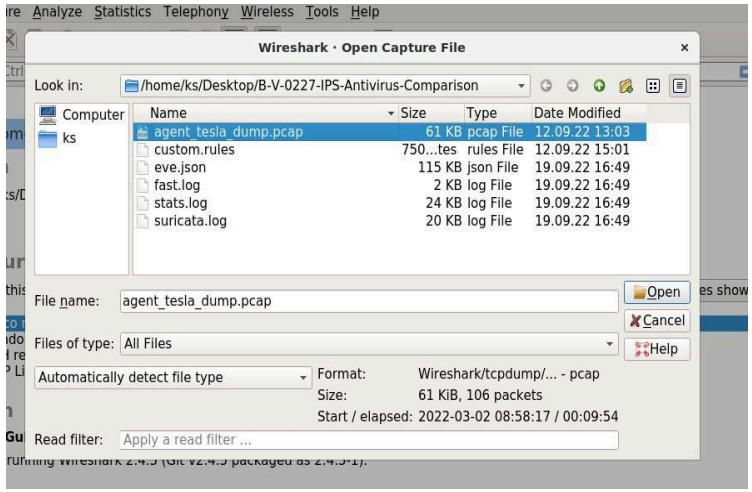
3. Open the file explorer and go to Downloads and find the PCAP file.

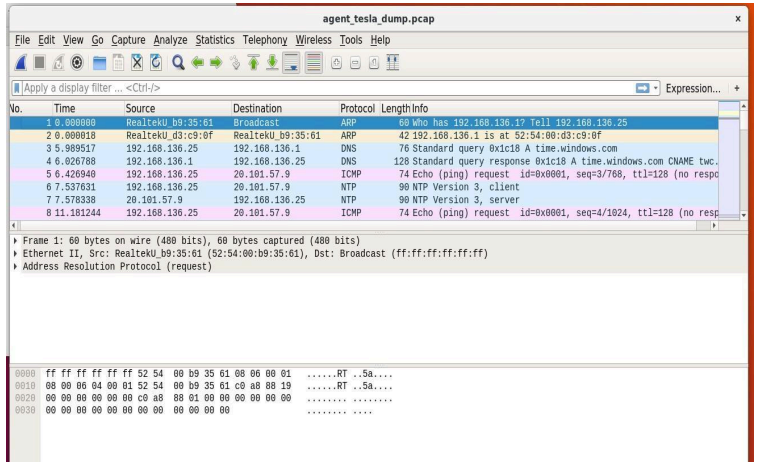


4. Run wireshark on terminal

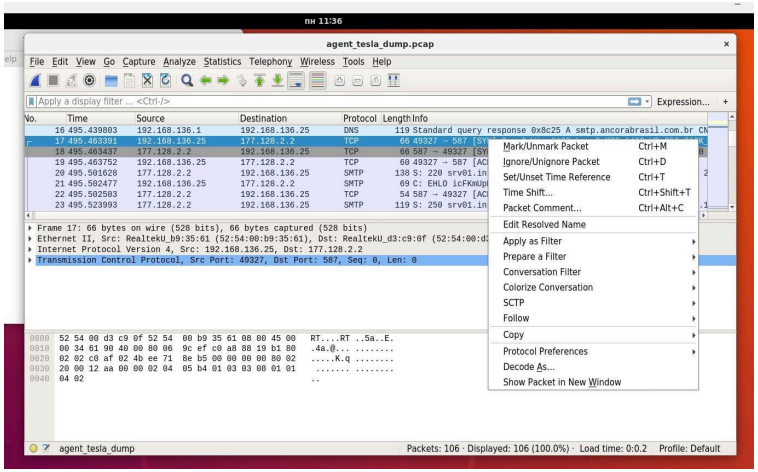


5. Navigate to ‘File’ and then ‘Open’. Search for *“agent_tesla_dump.pcap”* and double click to access it.



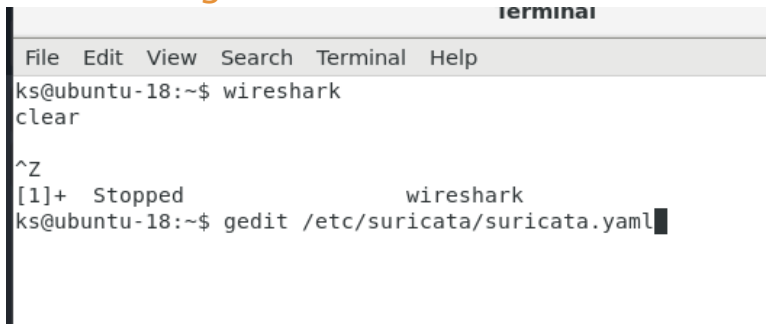


6. After the **PCAP** file is loaded, right-click on any packet and select ‘Follow’ and then ‘TCP stream’.

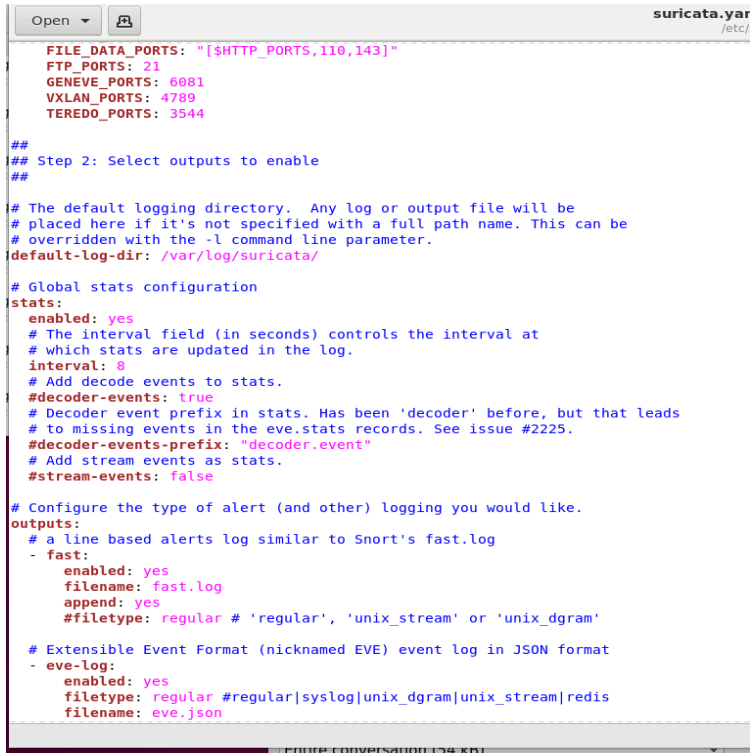




7. Executing suricata.



8. The text reader file.

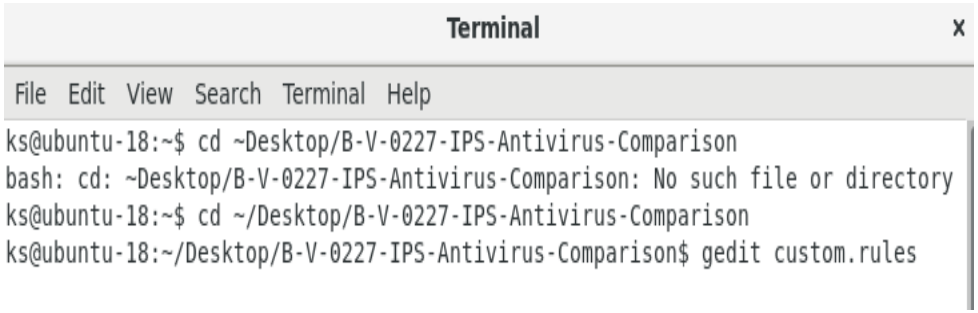


9. Viewing the Suricata rules option.

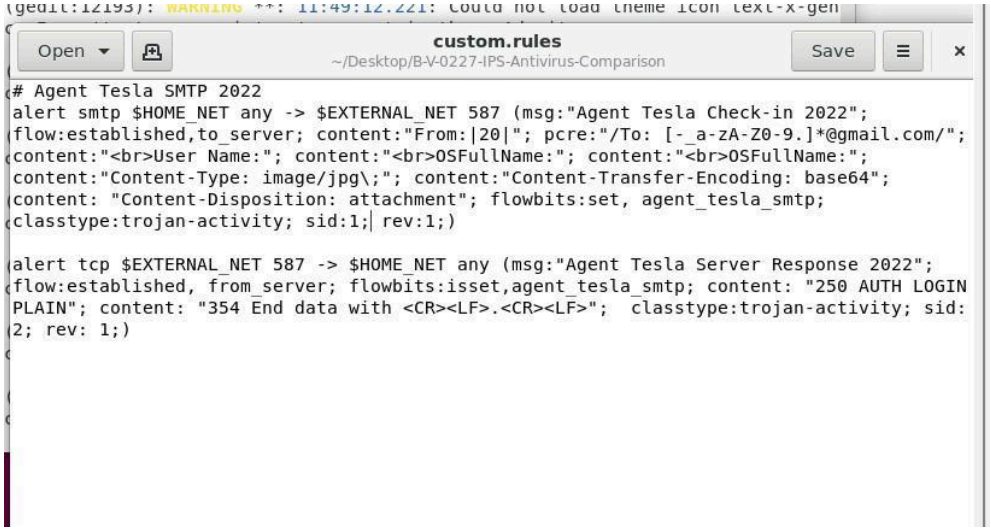
```
ks@ubuntu-18:~$ ls -C /etc/suricata/rules/
app-layer-events.rules  http2-events.rules     ntp-events.rules
custom.rules            http-events.rules      smb-events.rules
decoder-events.rules    ipsec-events.rules     smtp-events.rules
dhcp-events.rules       kerberos-events.rules  ssh-events.rules
dnp3-events.rules       modbus-events.rules    stream-events.rules
dns-events.rules        mqtt-events.rules      tls-events.rules
files.rules             nfs-events.rules
ks@ubuntu-18:~$
```

```
tats. Has been 'decoder' before, but that leads
eve.stats records. See issue #2225.
coder.event"
```

10. Execute the command ‘gedit custom.rules’.



11. Edited rule in the Text Editor.



12. The command is successfully executed.

```
ks@ubuntu-18:~/Desktop/B-V-0227-IPS-Antivirus-Comparison$ suricata -r agent_tesla_dump.pcap -S custom.rules -k none -v
13/4/2026 -- 11:54:19 - <Notice> - This is Suricata version 6.0.6 RELEASE running in USER mode
13/4/2026 -- 11:54:19 - <Info> - CPUs/cores online: 8
13/4/2026 -- 11:54:19 - <Info> - SSSE3 support not detected, disabling Hyperscan for MPM
13/4/2026 -- 11:54:19 - <Info> - SSSE3 support not detected, disabling Hyperscan for SPM
13/4/2026 -- 11:54:19 - <Warning> - [ERRCODE: SC_ERR_CONF_YAML_ERROR(242)] - App-Layer protocol sip enable status not set, so enabling by default. This behavior will change in Suricata 7,
ase update your config. See ticket #4744 for more details.
13/4/2026 -- 11:54:19 - <Warning> - [ERRCODE: SC_ERR_CONF_YAML_ERROR(242)] - App-Layer protocol mqtt enable status not set, so enabling by default. This behavior will change in Suricata 7,
ease update your config. See ticket #4744 for more details.
13/4/2026 -- 11:54:19 - <Warning> - [ERRCODE: SC_ERR_CONF_YAML_ERROR(242)] - App-Layer protocol rdp enable status not set, so enabling by default. This behavior will change in Suricata 7,
ase update your config. See ticket #4744 for more details.
13/4/2026 -- 11:54:19 - <Info> - fast output device (regular) initialized: fast.log
13/4/2026 -- 11:54:19 - <Info> - eve-log output device (regular) initialized: eve.json
13/4/2026 -- 11:54:19 - <Info> - stats output device (regular) initialized: stats.log
13/4/2026 -- 11:54:19 - <Info> - SSSE3 support not detected, disabling Hyperscan for SPM
13/4/2026 -- 11:54:19 - <Info> - 1 rule files processed. 2 rules successfully loaded, 0 rules failed
13/4/2026 -- 11:54:19 - <Info> - Threshold config parsed: 0 rule(s) found
13/4/2026 -- 11:54:19 - <Info> - 2 signatures processed. 0 are IP-only rules, 2 are inspecting packet payload, 0 inspect application layer, 0 are decoder event only
13/4/2026 -- 11:54:19 - <Notice> - all 9 packet processing threads, 4 management threads initialized, engine started.
13/4/2026 -- 11:54:19 - <Info> - Starting file run for agent_tesla_dump.pcap
13/4/2026 -- 11:54:19 - <Info> - pcap file agent_tesla_dump.pcap end of file reached (pcap err code 0)
13/4/2026 -- 11:54:19 - <Notice> - Signal Received.  Stopping engine.
```

13. Output of executing 'gedit fast.log'

Open | fast.log ~/Desktop/B-V-0227-IPS-Antivirus-Comparison | Save

```
03/02/2022-09:06:33.500245  [**] [1:1:1] Agent Tesla Check-in 2022 [**] [Classification: A Network
Trojan was detected] [Priority: 1] {TCP} 192.168.136.25:49327 -> 177.128.2.2:587
03/02/2022-09:08:12.532244  [**] [1:2:1] Agent Tesla Server Response 2022 [**] [Classification: A
Network Trojan was detected] [Priority: 1] {TCP} 177.128.2.2:587 -> 192.168.136.25:49327
03/02/2022-09:06:33.500245  [**] [1:1:1] Agent Tesla Check-in 2022 [**] [Classification: A Network
Trojan was detected] [Priority: 1] {TCP} 192.168.136.25:49327 -> 177.128.2.2:587
03/02/2022-09:08:12.532244  [**] [1:2:1] Agent Tesla Server Response 2022 [**] [Classification: A
Network Trojan was detected] [Priority: 1] {TCP} 177.128.2.2:587 -> 192.168.136.25:49327
03/02/2022-09:06:33.500245  [**] [1:1:1] Agent Tesla Check-in 2022 [**] [Classification: A Network
Trojan was detected] [Priority: 1] {TCP} 192.168.136.25:49327 -> 177.128.2.2:587
03/02/2022-09:08:12.532244  [**] [1:2:1] Agent Tesla Server Response 2022 [**] [Classification: A
Network Trojan was detected] [Priority: 1] {TCP} 177.128.2.2:587 -> 192.168.136.25:49327
03/02/2022-09:06:33.500086  [**] [1:1:1] Agent Tesla Check-in 2022 [**] [Classification: A Network
Trojan was detected] [Priority: 1] {TCP} 192.168.136.25:49327 -> 177.128.2.2:587
03/02/2022-09:08:12.532244  [**] [1:2:1] Agent Tesla Server Response 2022 [**] [Classification: A
Network Trojan was detected] [Priority: 1] {TCP} 177.128.2.2:587 -> 192.168.136.25:49327
03/02/2022-09:06:33.500245  [**] [1:1:1] Agent Tesla Check-in 2022 [**] [Classification: A Network
Trojan was detected] [Priority: 1] {TCP} 192.168.136.25:49327 -> 177.128.2.2:587
03/02/2022-09:08:12.532244  [**] [1:2:1] Agent Tesla Server Response 2022 [**] [Classification: A
Network Trojan was detected] [Priority: 1] {TCP} 177.128.2.2:587 -> 192.168.136.25:49327
03/02/2022-09:06:33.500245  [**] [1:1:1] Agent Tesla Check-in 2022 [**] [Classification: A Network
Trojan was detected] [Priority: 1] {TCP} 192.168.136.25:49327 -> 177.128.2.2:587
03/02/2022-09:08:12.532244  [**] [1:2:1] Agent Tesla Server Response 2022 [**] [Classification: A
Network Trojan was detected] [Priority: 1] {TCP} 177.128.2.2:587 -> 192.168.136.25:49327
03/02/2022-09:06:33.500245  [**] [1:1:1] Agent Tesla Check-in 2022 [**] [Classification: A Network
Trojan was detected] [Priority: 1] {TCP} 192.168.136.25:49327 -> 177.128.2.2:587
03/02/2022-09:08:12.532244  [**] [1:2:1] Agent Tesla Server Response 2022 [**] [Classification: A
Network Trojan was detected] [Priority: 1] {TCP} 177.128.2.2:587 -> 192.168.136.25:49327
03/02/2022-09:06:33.500086  [**] [1:1:1] Agent Tesla Check-in 2022 [**] [Classification: A Network
Trojan was detected] [Priority: 1] {TCP} 192.168.136.25:49327 -> 177.128.2.2:587
03/02/2022-09:08:12.532244  [**] [1:2:1] Agent Tesla Server Response 2022 [**] [Classification: A
Network Trojan was detected] [Priority: 1] {TCP} 177.128.2.2:587 -> 192.168.136.25:49327
```

14. ClamAV scanned the Downloads folder and out of 49 scanned files, 1 file was flagged as infected.

```
ks@ubuntu-18:~/Desktop/B-V-0227-IPS-Antivirus-Comparison$
ks@ubuntu-18:~/Desktop/B-V-0227-IPS-Antivirus-Comparison$ clamscan -r --bell -i ~/Downloads

----------- SCAN SUMMARY -----------
Known viruses: 8644877
Engine version: 0.103.6
Scanned directories: 39
Scanned files: 49
Infected files: 1
Data scanned: 41.61 MB
Data read: 62.65 MB (ratio 0.66:1)
Time: 36.357 sec (0 m 36 s)
Start Date: 2026:04:13 12:00:03
End Date:   2026:04:13 12:00:40
ks@ubuntu-18:~/Desktop/B-V-0227-IPS-Antivirus-Comparison$
```

15. ClamAV scan a directory with 502 files and 475 files were flagged as infected.

```
ks@ubuntu-18:~/Desktop/B-V-0227-IPS-Antivirus-Comparison$ cd ~/Documents/Linux-Malware-Samples
ks@ubuntu-18:~/Documents/Linux-Malware-Samples$ clamscan -r --bell -i ~/Documents/Linux-Malware-Samples

----------- SCAN SUMMARY -----------
Known viruses: 8644877
Engine version: 0.103.6
Scanned directories: 18
Scanned files: 502
Infected files: 475
Data scanned: 1132.27 MB
Data read: 1575.36 MB (ratio 0.72:1)
Time: 145.188 sec (2 m 25 s)
Start Date: 2026:04:13 12:04:49
End Date:   2026:04:13 12:07:14
ks@ubuntu-18:~/Documents/Linux-Malware-Samples$
```

16. Re-running ClamAV scan at the same directory after creating a new hash signature 'NewSignature.hdb'

```
ks@ubuntu-18:~/Documents/Linux-Malware-Samples$ sudo cp NewSignature.hdb /var/lib/clamav/
[sudo] password for ks:
```

